

CHALLENGE 4: Manomissione input

Scenario:

L'applicazione offre una funzionalità di “suggerimento notizie” durante la creazione di un articolo. L'utente seleziona una fonte da un menu a tendina, ma il valore inviato al server è un URL arbitrario.

Un attaccante con conoscenze di base può modificare l'HTML tramite “Ispeziona elemento” e inserire un URL interno, come `http://internal.finance:8001/user-data.php`, per accedere a dati sensibili.

Attacco eseguito

Accesso come utente writer (ruolo non privilegiato)

Modifica della select con DevTools, impostando:

```
<option
```

```
value="http://internal.finance:8001/user-data.php">NewsAPI -
```

```
IT</option>
```

```

<form action="http://cyber.blog:8000/articles/store" method="POST" class="card p-5 shadow" enctype="multipart/form-
ata">
</form>
<div wire:snapshot="{"data":{"selectedApi":"http://\internal.finance:8001/user-data.php","news":[{"users":[{"use
r_id":1,"username":"john_doe","account_balance":1500.75,"transactions":[{"transaction_id":"txn001","date":"2024-06
-15","amount":50.25,"description":"Grocery Store"},{"s":"arr"},[{"transaction_id":"txn002","date":"2024-06-20","am
ount":500,"description":"Salary Deposit"},{"s":"arr"}]},{"s":"arr"},[{"card_number":"4111-1111-1111-1
111","expiry_date":"12/26","cvv":"123"},{"s":"arr"}]},{user_id:2,"username":"jane_smith","account_b
alance":3200,"transactions":[{"transaction_id":"txn003","date":"2024-06-10","amount":-120.75,"description":"Online
Shopping"},{"s":"arr"},[{"transaction_id":"txn004","date":"2024-06-25","amount":1500,"description":"Freelance Payme
nt"},{"s":"arr"}]},{s":"arr"},[{"card_number":"5500-0000-0000-0004","expiry_date":"11/25","cvv":"45
6"},{"s":"arr"}]},{s":"arr"},[{"user_id":3,"username":"mark_jones","account_balance":875.5,"transactions":[{"tra
nsaction_id":"txn005","date":"2024-06-18","amount":-75.5,"description":"Restaurant"},{"s":"arr"},[{"transaction_i
d":"txn006","date":"2024-06-22","amount":200,"description":"Gift from Friend"},{"s":"arr"}]},{s":"arr"},[{"credit_ca
rd":{"card_number":"3782-822463-10005","expiry_date":"05/24","cvv":"789"},{"s":"arr"}]},{s":"arr"},[{"user_id":
4,"username":"anna_brown","account_balance":2200.5,"transactions":[{"transaction_id":"txn007","date":"2024-07-0
5","amount":-100,"description":"Electric Bill"},{"s":"arr"},[{"s":"arr"},[{"card_number":"1234-5678-
9101-1121","expiry_date":"06/25","cvv":"321"},{"s":"arr"}]},{s":"arr"},[{"user_id":5,"username":"tom_clark","acco
unt_balance":480,"transactions":[{"transaction_id":"txn008","date":"2024-07-10","amount":-30,"description":"Movie
Tickets"},{"s":"arr"},[{"transaction_id":"txn009","date":"2024-07-12","amount":-25,"description":"Lunch"},{"s":"ar
r"},[{"transaction_id":"txn010","date":"2024-07-15","amount":100,"description":"Gift from Aunt"},{"s":"arr"}]},{
s":"arr"},[{"credit_card":{"card_number":"5432-1098-7654-3210","expiry_date":"04/24","cvv":"654"},{"s":"arr"}]},{
s":"arr"},[{"user_id":6,"username":"susan_davis","account_balance":5000,"transactions":[{"transaction_id":"txn0
11","date":"2024-07-20","amount":-250,"description":"New Laptop"},{"s":"arr"},[{"transaction_id":"txn012","date":"2
024-07-22","amount":500,"description":"Freelance Work"},{"s":"arr"},[{"transaction_id":"txn013","date":"2024-07-2
5","amount":-100,"description":"Dinner"},{"s":"arr"},[{"transaction_id":"txn014","date":"2024-07-27","amount":-5
0,"description":"Groceries"},{"s":"arr"},[{"s":"arr"},[{"card_number":"6789-0123-4567-8901","expiry
date":"09/26","cvv":"987"},{"s":"arr"}]},{s":"arr"},[{"user_id":7,"username":"mike_lee","account_balance":1340,"t
ransactions":[{"transaction_id":"txn015","date":"2024-07-08","amount":-40,"description":"Book Purchase"},{"s":"ar
r"},[{"transaction_id":"txn016","date":"2024-07-15","amount":120,"description":"Freelance Work"},{"s":"arr"}]},{
s":"arr"},[{"credit_card":{"card_number":"9101-1234-5678-4321","expiry_date":"03/27","cvv":"098"},{"s":"arr"}]},{
s":"arr"},[{"user_id":8,"username":"nancy_moore","account_balance":980.75,"transactions":[{"transaction_id":"tx
n017","date":"2024-07-01","amount":-60.25,"description":"Gas"},{"s":"arr"},[{"transaction_id":"txn018","date":"2024
-07-10","amount":300,"description":"Part-time Job"},{"s":"arr"}]},{s":"arr"},[{"credit_card":{"card_number":"2345-6
789-0123-4567","expiry_date":"02/25","cvv":"765"},{"s":"arr"}]},{s":"arr"},[{"user_id":9,"username":"paul_jackso
n","account_balance":2000,"transactions":[{"transaction_id":"txn019","date":"2024-07-03","amount":-150,"descriptio
n":"Concert Tickets"},{"s":"arr"}]},{s":"arr"},[{"credit_card":{"card_number":"3456-7890-1234-5678","expiry_date":
"08/24","cvv":"432"},{"s":"arr"}]},{s":"arr"},[{"user_id":10,"username":"linda_jones","account_balance":4500.5,"t
ransactions":[{"transaction_id":"txn020","date":"2024-07-05","amount":-100.5,"description":"Fitness Equipment"},
{"s":"arr"},[{"transaction_id":"txn021","date":"2024-07-07","amount":-200,"description":"Furniture"},{"s":"arr"}]},{
s":"arr"},[{"transaction_id":"txn022","date":"2024-07-15","amount":1500,"description":"Project Payment"},{"s":"arr"}]},{s":"ar
r"},[{"credit_card":{"card_number":"4567-8901-2345-6789","expiry_date":"10/25","cvv":"109"},{"s":"arr"}]},{s":"ar
r"},[{"user_id":11,"username":"jason_miller","account_balance":150.25,"transactions":[{"transaction_id":"txn02
3","date":"2024-07-12","amount":-20,"description":"Coffee Shop"},{"s":"arr"},[{"transaction_id":"txn024","date":"26
24-07-15","amount":50,"description":"Gift from Friend"},{"s":"arr"}]},{s":"arr"},[{"card_number":"56
78-9012-3456-7890","expiry_date":"07/26","cvv":"210"},{"s":"arr"}]},{s":"arr"},[{"user_id":12,"username":"sarah_t
aylor","account_balance":2900,"transactions":[{"transaction_id":"txn025","date":"2024-07-05","amount":-300,"descri
ption":"Airline Tickets"},{"s":"arr"},[{"transaction_id":"txn026","date":"2024-07-10","amount":800,"description":"F
reelance Work"},{"s":"arr"}]},{s":"arr"},[{"credit_card":{"card_number":"6789-0123-4567-8901","expiry_date":"11/2
6","cvv":"321"},{"s":"arr"}]},{s":"arr"},[{"user_id":13,"username":"david_wilson","account_balance":675,"transacti
ons":[{"transaction_id":"txn027","date":"2024-07-01","amount":-75,"description":"Groceries"},{"s":"arr"},[{"trans
action_id":"txn028","date":"2024-07-15","amount":200,"description":"Freelance Work"},{"s":"arr"}]},{{"transaction_i

```

Risultato: il server ha eseguito la richiesta interna e restituito dati finanziari sensibili, inclusi:

- Nomi utenti
- Numeri di carte di credito...

Mitigazione:

Per prevenire la manomissione input e l'SSRF, ho applicato due livelli di protezione:

Whitelist delle fonti nel componente Livewire

Il valore selezionato dall'utente non è più un URL libero, ma una chiave fissa (newsapi-it, newsapi-us).

Gli URL reali sono mappati lato server, impedendo qualsiasi input arbitrario.

Controllo ruolo nel servizio HTTP

Anche se un attaccante bypassa il primo controllo, il servizio `HttpService.php` verifica:

Se il dominio è `internal.finance`

Se l'utente è admin

In caso negativo, la richiesta è bloccata.

```
▼ <div wire:snapshot="{\"data\":{\"selectedApi\":\"http:\\/\\/internal.finance:8001\\/user-data.php\", \"news\":null, \"memo\":{\"id\": \"h1UZSBhGH9g0oGmxeZIX\", \"name\":\"latest-news\", \"path\":\"articles\\/create\", \"method\":\"GET\", \"release\":\"a-a-a\", \"children\":[] , \"scripts\":[] , \"assets\":[] , \"errors\":[] , \"locale\":\"en\"}, \"checksum\":\"f1d815ab3254dee3e27ae0a0c512b7768432f3746f768813901d6 11496354add\"}\" wire:effects=\"{\"returns\":[]}\" wire:id=\"h1UZSBhGH9g0oGmxeZIX\"}> == $0 🔗
  <label for=\"source\">Scegli una fonte per ispirarti:</label>
  ▼ <select wire:model.live=\"selectedApi\" class=\"form-control\">
    <option value-- Scegli --></option> 🔗 slot
    <option value=\"newsapi-it\">NewsAPI - IT</option> 🔗 slot
    <option value=\"newsapi-us\">NewsAPI - US</option> 🔗 slot
  </select>
  <button wire:click=\"fetchNews\" class=\"btn btn-primary mt-2\">Carica ultime notizie</button>
  <!--[if BLOCK]><![endif]-->
  <!--[if ENDBLOCK]><![endif]-->
```

In `LatestNews.php`:

```
$allowedSources = [
    'newsapi-it' => 'https://newsapi.org/...',
    'newsapi-us' => 'https://newsapi.org/...'
];
if (!isset($allowedSources[$this->selectedApi])) {
    $this->news = 'Fonte non autorizzata';
    return;
}
```

In `HttpService.php`:

```
if ($parsedUrl['host'] === 'internal.finance') {
    if (!Auth::check() || !Auth::user()->is_admin) {
        return 'Access denied: only admins can access internal
financial data';
    }
}
```

Conclusione:

La vulnerabilità SSRF è stata eliminata grazie a:

Validazione rigorosa degli input (whitelist)

Controllo dei ruoli per l'accesso a risorse interne

Ora l'applicazione rispetta il principio del minimo privilegio.